

ACTIVITY PACK

Activity 1: Discussion Questions

Activity 1 - Threat Modelling a Generative AI Concierge

Course	AI Security for Autonomous AI Agents
Course code	TGS-2025060473
Version	3.0 20 August 2026

Tertiary Infotech Pte Ltd | UEN 20120096W

Discussion Questions

Activity 1 - Discussion Questions

Threat Modelling a Generative AI Concierge

Work through all five questions in your group. Nominate one person to present your threat model in the debrief. You have 45 minutes.

Q1 - Map the trust boundaries (K2)

Draw the data flow for Cres: the three channels in, the four retrieval sources, and the four tool actions out.

- Mark every point where **untrusted content** enters the model's context window.
- For each, state **who controls that content** and whether the hotel can verify it.
- The model cannot reliably tell the difference between the hotel's instructions and text that

merely *appears* in its context. Explain, in language the executive committee would follow, **why this is a property of how generative models work** rather than a bug the vendor can patch.

Q2 - Rank the retrieval sources by risk (K2, K3)

Of the four retrieval sources, two are **attacker-writable** in practice.

- Identify which two, and explain the path by which an outsider gets text into them.
- The project lead proposes adding "a classifier that detects malicious instructions before they

reach the model." That classifier is a **discriminative** model policing a **generative** one. Explain what that classifier can and cannot do, and why it is a control worth having but not a control worth trusting on its own.

Q3 - Turn each capability into an attack surface (A4)

Cres performs four application functions: **summarisation** (reviews, event listings), **inference** (guest preferences), **transformation** (formatting a folio), and **augmentation** (enriching answers from retrieval).

For **each** of the four, describe one concrete way an attacker abuses that specific function. Be precise about the attacker's goal - data, money, disruption or reputation.

Q4 - Explain the three early signals (K2, A4)

The three incidents in the scenario are not unrelated glitches.

- Give the most likely technical cause of each.
- Which events require a formal PDPA breach assessment? Apply the current significant-harm and significant-scale tests without assuming that every data leak is automatically notifiable.
- The project lead says PDPA is not in scope because Cres holds no payment card data. Rebut this.

Q5 - Recommend the deployment decision (A4)

The committee wants a one-slide answer for the rollout to three more properties.

- Recommend **proceed**, **proceed with conditions**, or **halt**, and justify it.
- List the **three** controls you would require before any further rollout, in priority order.
- For each control, name what it costs the business - latency, money, guest friction or staff effort. A recommendation that pretends controls are free will not survive the committee.